

FTP — File Transfer Protocol

Servicio

FTP (File Transfer Protocol)

Puerto por defecto

21/TCP (control) · 20/TCP (datos en modo activo)

Descripción

FTP es un protocolo estándar de red utilizado para transferir archivos entre un cliente y un servidor en una red TCP/IP. Fue diseñado en 1971 (RFC 114) y estandarizado en RFC 959 (1985). Opera con dos canales separados: uno de control (puerto 21) y uno de datos (puerto 20 o efímero en modo pasivo). **No cifra ni las credenciales ni los datos transferidos.**

Riesgos de seguridad

- **Transmisión sin cifrado:** Las credenciales (usuario y contraseña) y todos los datos se transmiten en texto plano, visibles en cualquier captura de tráfico.
- **Captura de credenciales (sniffing):** Cualquier atacante con acceso a la red puede interceptar las credenciales FTP con herramientas como Wireshark.
- **FTP anónimo habilitado:** Permite a cualquier usuario acceder sin autenticación, exponiendo archivos potencialmente sensibles.
- **Ataques de fuerza bruta:** Ausencia de mecanismos de bloqueo permite ataques de diccionario sobre las credenciales.
- **Bounce attacks:** El modo activo FTP puede ser abusado para escanear redes internas usando el servidor FTP como proxy.
- **Directory traversal:** Configuraciones incorrectas pueden permitir salir del directorio raíz del servidor.

Escenarios de ataque

1. **Sniffing de credenciales:** Un atacante con posición de red intermedia (ARP spoofing) captura el tráfico y obtiene usuario y contraseña en claro.
2. **Acceso anónimo no intencionado:** Un administrador habilita FTP anónimo para facilitar descargas y expone accidentalmente directorios sensibles.
3. **Fuerza bruta:** Herramientas como Hydra atacan el servicio FTP con listas de contraseñas comunes.
4. **FTP Bounce Attack:** El atacante usa el comando PORT para redirigir conexiones de datos hacia hosts internos, saltando firewalls.

Mitigaciones recomendadas

- **Reemplazar FTP por SFTP** (SSH File Transfer Protocol, puerto 22) o **FTPS** (FTP sobre TLS, puertos 990/989).
- Deshabilitar el acceso anónimo (`anonymous_enable=NO` en `vsftpd`).
- Restringir FTP a usuarios específicos con `chroot jail` (confinamiento al directorio `home`).
- Implementar listas blancas de IP y firewall para limitar quién puede conectarse.
- Si se debe mantener FTP, cifrar el canal de control y datos con TLS (FTPS explícito).
- Auditar periódicamente los logs de acceso y habilitar alertas de fuerza bruta.
- Usar **fail2ban** para bloquear IPs con intentos de login fallidos repetidos.

Nivel de exposición

Alto

Referencias

- Postel, J. & Reynolds, J. *RFC 959 — File Transfer Protocol*. IETF, 1985. <https://www.rfc-editor.org/rfc/rfc959>
- CISA. *Secure Configuration Guidance*. <https://www.cisa.gov>
- NIST SP 800-177 — Trustworthy Email (referencias a protocolos de transferencia inseguros). <https://csrc.nist.gov>
- OWASP. *Testing for Weak SSL/TLS Ciphers* (aplica a FTPS). <https://owasp.org/www-project-web-security-testing-guide/>